

Reconnaissance Tool Report

OWASP Amass – Attack Surface Mapping & Asset Discovery

Tool Version: v4.2.0 | Platform: Kali Linux
Prepared for: HR / Internal Training Submission

1. Introduction

Amass is an open-source reconnaissance and attack-surface mapping tool maintained under the OWASP Foundation. It is used during the information-gathering phase of a security assessment to discover an organization's internet-facing assets — primarily subdomains, IP address ranges, ASNs, and the relationships between them. Amass combines open-source intelligence (OSINT) collection, active DNS enumeration, web archive scraping, certificate transparency log analysis, and brute-force/permutation techniques into a single framework.

This report summarizes the tool's purpose, architecture, installation status on Kali Linux, and the core commands used to operate it, along with sample output and practical use cases.

2. Tool Overview

Attribute	Details
Name	OWASP Amass
Category	Subdomain enumeration / Attack surface mapping / OSINT
Language	Go (Golang)
Maintainer	OWASP Foundation
Version Used	v4.2.0

3. Key Features

- Passive information gathering from 40+ open-source intelligence sources (no direct contact with the target).
- Active enumeration using DNS resolution, zone transfers, brute forcing and permutation scanning.
- Certificate transparency (CT) log searching to reveal issued subdomains.
- Reverse DNS sweeps and IP-to-ASN/Netblock correlation.
- Graph database backend that stores relationships between discovered assets across scans.
- Built-in visualization output (DOT, GEXF, D3 JS graphs) for mapping the discovered attack surface.
- Modular subcommands: intel, enum, viz, track, db, and dns.

4. Installation & Version Verification

Amass comes pre-installed on Kali Linux. The installed version can be verified using:

```
amass -version
```

Expected output:

```
v4.2.0
```

If a re-install or update is ever required:

```
sudo apt update
sudo apt install amass -y
```

5. Command Reference

Amass is organized into subcommands, each responsible for a distinct part of the reconnaissance workflow.

5.1 amass enum – Subdomain Enumeration

The core module used to actively and passively discover subdomains belonging to a target domain.

```
# Basic passive enumeration (no active DNS resolution)
amass enum -passive -d example.com
```



```
(dharmik@kali)-[~/amass_Linux_amd64]
$ amass enum -passive -d broaderai.com
broaderai.com (FQDN) → mx_record → broaderai-com.mail.protection.outlook.com (FQDN)
broaderai.com (FQDN) → ns_record → ns1.dns-parking.com (FQDN)
broaderai.com (FQDN) → ns_record → ns2.dns-parking.com (FQDN)
The enumeration has finished
```

```
# Full active enumeration (passive + active DNS + brute force)
amass enum -active -d example.com -o output.txt
```

```
# Enumerate with brute forcing enabled using a wordlist
amass enum -active -d example.com -brute -w /usr/share/wordlists/subdomains.txt
```

```
# Multiple domains from a file
amass enum -active -df domains.txt -o results.txt
```

5.2 amass intel – Target/ASN Discovery

Used before enumeration to discover related domains, IP ranges, and ASN ownership tied to an organization.

```
# Discover domains associated with an organization name
amass intel -org "Example Corp"
```

```
# Discover domains from a known IP range
amass intel -cidr 192.0.2.0/24
```

```
# Reverse whois style discovery by ASN
amass intel -asn 15169
```

5.3 amass viz – Visualization

Generates a visual graph of the relationships between discovered assets from a prior scan stored in the graph database.

```
# Export a DOT graph (viewable with Graphviz)
amass viz -d example.com -dot

# Export a D3.js interactive HTML visualization
amass viz -d example.com -d3
```

5.4 amass track – Change Tracking

Compares the results of enumerations run at different points in time to identify newly added or removed assets.

```
amass track -d example.com
```

5.5 amass db – Database Operations

Queries and manages the local graph database that stores results from previous scans.

```
# Show all names discovered for a domain from stored scans
amass db -names -d example.com

# List completed enumerations stored in the database
amass db -list
```

6. Detailed Command Explanations

This section explains what each command and flag actually does, and why it is used at that stage of a reconnaissance workflow.

6.1 amass enum – Main Enumeration Engine

```
amass enum -passive -d example.com
```

- `-passive`: Restricts collection to third-party OSINT sources only (certificate transparency logs, search engines, public datasets). No traffic is ever sent to the target domain itself, making this fast, quiet, and low-risk.
- `-d example.com`: Sets the domain being enumerated.

```
amass enum -active -d example.com -o output.txt
```

- `-active`: Adds DNS resolution, zone transfer attempts, and reverse DNS sweeps on top of passive collection. This directly interacts with the target's infrastructure and should only be used with authorization.
- `-o output.txt`: Writes all discovered subdomains to a file instead of only printing them to the screen.

```
amass enum -active -d example.com -brute -w /usr/share/wordlists/subdomains.txt
```

- `-brute`: Enables brute-force guessing, where Amass tries common subdomain names (dev, api, staging, etc.) against the target.
- `-w <path>`: Specifies which wordlist to use for brute forcing. If omitted, Amass falls back to its built-in default list.

```
amass enum -active -df domains.txt -o results.txt
```

- -df domains.txt: Reads multiple target domains from a file (one per line) instead of a single -d domain — useful for scoping an entire organization's domain portfolio at once.

6.2 amass intel – Determining What to Target

The intel subcommand is typically run before enumeration, to establish which domains, IP ranges, or networks belong to the target organization.

```
amass intel -org "Example Corp"
```

- -org: Searches WHOIS-style registration records to find domains registered under a given company name. This is usually the first step — discovering what domains an organization actually owns.

```
amass intel -cidr 192.0.2.0/24
```

- -cidr: Accepts an IP address range (CIDR block) and finds domains hosted within it. Useful when an IP range is known but the associated domains are not.

```
amass intel -asn 15169
```

- -asn: Accepts an Autonomous System Number, which identifies a network block owned by an organization or ISP, and returns domains associated with it. Useful for mapping a large organization's full network footprint (e.g. ASN 15169 belongs to Google).

6.3 amass viz – Turning Results Into a Visual Graph

```
amass viz -d example.com -dot
```

- Reads results already stored in Amass's local graph database from earlier enum scans and exports a .dot file, viewable in Graphviz, showing how subdomains, IPs, and ASNs relate to one another.

```
amass viz -d example.com -d3
```

- Exports the same relationship data as an interactive HTML/D3.js graph that can be explored in a web browser.

6.4 amass track – Detecting Changes Over Time

```
amass track -d example.com
```

- Compares the current scan's results against a previous scan of the same domain and reports newly added or removed assets. This is used for ongoing monitoring rather than a single one-off scan.

6.5 amass db – Querying Stored Scan History

```
amass db -names -d example.com
```

- Pulls every subdomain name ever discovered for that domain across all previous scans stored locally, without running a new scan.

```
amass db -list
```

- Lists every past enumeration session stored in the database, providing a quick view of scan history.

6.6 Recommended Command Order

- 1. amass intel -org "..." — discover what domains exist for the organization.

- 2. `amass enum -passive -d ...` — run a quick, safe first pass.
- 3. `amass enum -active -brute -d ...` — run a deeper active pass once scope is confirmed.
- 4. `amass viz -d ... -dot` — visualize the collected results.
- 5. `amass track -d ...` — re-run later to catch newly added assets.

7. Common Flags Reference

Flag	Description
<code>-d</code>	Target domain to enumerate
<code>-df</code>	File containing a list of domains
<code>-passive</code>	Restrict to passive OSINT sources only (fastest, least intrusive)
<code>-active</code>	Enables active techniques such as DNS resolution and zone transfer attempts
<code>-brute</code>	Enables brute-force subdomain guessing using a wordlist
<code>-w</code>	Path to a custom wordlist for brute forcing
<code>-o</code>	Write output results to a text file
<code>-json</code>	Write results in JSON format
<code>-src</code>	Display which OSINT source each result came from
<code>-ip</code>	Show resolved IP addresses alongside discovered names

8. Sample Output

Example output from a passive enumeration run (illustrative):

```
www.example.com
mail.example.com
dev.example.com
api.example.com
vpn.example.com

Amass v4.2.0
Avg/sec: 4.32
Names Discovered: 5
```

9. Use Cases

- Pre-engagement reconnaissance during authorized penetration testing to map an organization's external footprint.
- Bug bounty scoping — identifying in-scope subdomains before vulnerability testing begins.
- Attack surface management — continuously tracking an organization's own exposed assets over time.
- Red team asset discovery for planning phishing or infrastructure-based engagements (with authorization).
- Security audits to identify forgotten or shadow IT subdomains left publicly exposed.

11. Conclusion

Amass v4.2.0 is a comprehensive and actively maintained OSINT and DNS enumeration framework that plays a key role in the reconnaissance phase of security assessments. Its modular design — spanning intelligence gathering, enumeration, visualization, and change tracking — makes it a versatile addition to a penetration tester's or security analyst's toolkit for building an accurate picture of an organization's external attack surface.